LE DÉFI · UNE APPLICATION DE FICHIERS

On demande un fichier. Le serveur suit le chemin.

LE DOSSIER PRÉVU

`uploads / utilisateur`

Les fichiers de notre compte.

`../`

remonter



AILLEURS SUR LE SERVEUR

`app.py · challenge.db`

Le code et la base de comptes.

`/download/…` Chemin contrôlé

`/raw?filename=…` Chemin non contrôlé

Schéma du comportement décrit dans le journal, pas une capture de l’application.

L’IDÉE À RETENIR

Le point faible : **laisser un nom de fichier sortir du dossier prévu.**

LE DÉCLIC · NE PAS S’ARRÊTER AU PREMIER TEXTE PLAUSIBLE

Un faux flag dans la base.
Une vraie piste juste à côté.

LE PIÈGE Un mot de passe ressemblait à un flag. LEURRE

01

Lire les comptes

La base contient aussi un compte administrateur.

→

02

Se connecter

Le tableau de bord admin montre d’autres fichiers.

→

03

Suivre l’indice

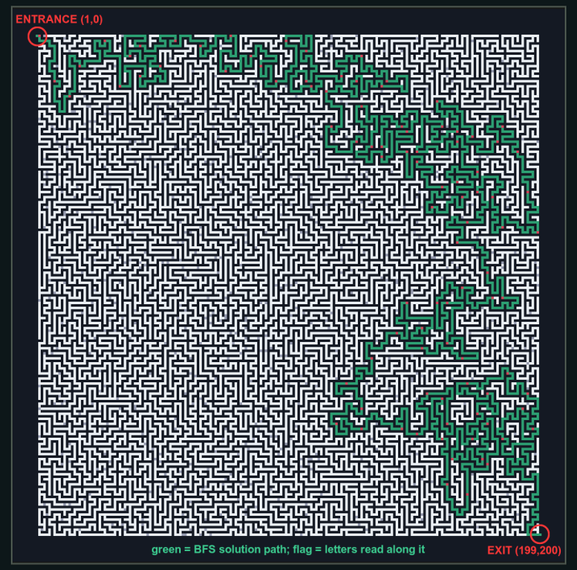
`flag.txt` indique que le flag est caché dans `flag.maze`.

L’IDÉE À RETENIR

Le bon chemin mène à **un labyrinthe de caractères.**

LA RÉSOLUTION · SUIVRE LE LABYRINTHE

Le chemin vers la sortie écrit le flag.



PREUVE CONSERVÉE · CLIQUER POUR AGRANDIR

201 × 201 cases dans le labyrinthe

1. Partir de l’entrée.
2. Explorer les passages accessibles.
3. Lire les lettres du chemin vers la sortie.

2 783 POSITIONS SUR LE CHEMIN

`BA26{tHis_Is_a_rEally_loNG_flag_…}`

L’IDÉE À RETENIR

L’accès aux fichiers ouvre la porte. **Le parcours du labyrinthe donne la réponse.**